BROKEN TRUST

Teoría de Access Control & Business Logic

VANGUARDIUN ACADEMY 2026

Fundamentos del Acceso

Entendiendo la diferencia crítica entre AuthN y AuthZ.

Autorización vs Autenticación

AuthN (Autenticación)

Responde a: **¿Quién eres?** Valida la identidad del usuario mediante tokens, contraseñas o MFA. Es la llave que abre la puerta principal.

AuthZ (Autorización)

Responde a: **¿Qué puedes hacer?** Valida los privilegios sobre objetos específicos. Es el permiso para entrar a habitaciones concretas.

Modelos de Control de Acceso

RBAC

Control basado en Roles. Permisos asignados a funciones (User, Admin). El fallo ocurre cuando el servidor no valida el rol.

ABAC

Control basado en Atributos. Restricciones por IP, horario o departamento. Vulnerable si los atributos son manipulables.

BOLA

Broken Object Level Authorization. El fallo de autorización a nivel de objeto más crítico en APIs modernas.

Escalada de Privilegios Vertical

Ocurre cuando un usuario accede a funciones de una jerarquía superior.

- Acceso directo a rutas administrativas no protegidas.
- Manipulación de cookies de rol (is_admin=true).
- Inyección de parámetros en el perfil de usuario.
- Falta de validación de estado en el backend.

Escalada Horizontal (IDOR)

Insecure Direct Object Reference

Un usuario accede a recursos de otro usuario del mismo nivel simplemente manipulando un identificador. El servidor confía ciegamente en el ID enviado por el cliente sin verificar la propiedad del recurso. Es la base de las filtraciones masivas de datos en plataformas SaaS y aplicaciones web modernas.

Anatomía de un IDOR

- **Identificadores Directos:** Uso de números secuenciales o UUIDs predecibles en la URL o cuerpo de la petición.
- **Vectores de Ataque:** URLs (?id=123), Parámetros POST, Headers, y objetos dentro de peticiones JSON o XML.
- **Falta de Contexto:** El backend ejecuta la consulta SELECT * FROM orders WHERE id=? sin añadir AND owner_id=?.
- **Impacto Crítico:** Exfiltración masiva de Información Personal Identificable (PII), modificación de pedidos o borrado de cuentas de terceros.

Mass Assignment: Teoría

Ocurre cuando el servidor mapea automáticamente la entrada del usuario a objetos de la base de datos sin filtrar

Petición Original	Inyección Maliciosa	Causa Raíz
{"email": "qbit@io"}	{"role": "admin"}	Confianza en el framework de mapeo (ORM).
{"name": "David"}	{"balance": 9999}	Falta de listas blancas de campos editables.

Bypass por Método HTTP

Verb Tampering

Los WAFs o filtros de seguridad suelen inspeccionar solo el método **POST** por ser el que modifica datos. Si el servidor acepta **GET** para la misma acción, el filtro se salta.

Headers de Engaño

Uso de encabezados como X-HTTP-Method-Override: POST para enviar un GET que el backend procesará como una acción administrativa de cambio de estado.

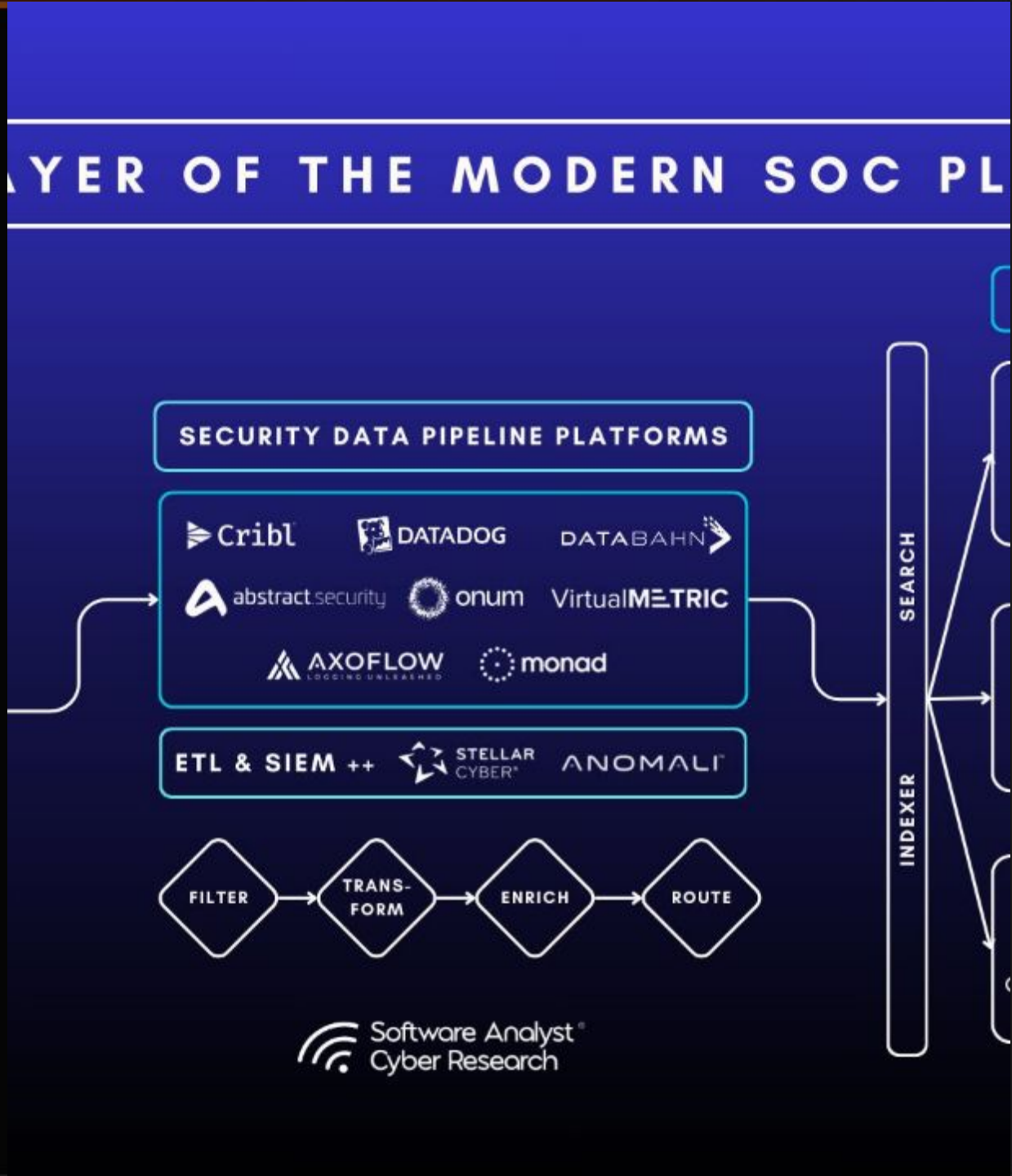
Bypass de URL (Headers)

Discrepancia de Interpretación

Basado en cómo el Proxy (Nginx/Apache) y el Backend (Framework) leen la URL solicitada.

```
GET / HTTP/1.1
X-Original-URL: /admin/deleteUser
```

El Proxy deja pasar la petición a "/" (permitida), pero el framework interno lee el header y ejecuta la ruta restringida.



Business Logic Flaws

Cuando el proceso de negocio está roto, el código no sirve para nada.

Definición de Fallos Lógicos

Sin Firmas

No hay una cadena de texto maliciosa. Los datos son sintácticamente correctos, pero la **intención** del proceso está subvertida.

Falla de Diseño

El atacante encuentra "agujeros" entre las reglas del negocio, abusando de flujos de trabajo inconsistentes o mal definidos.

Criterio Humano

Es el punto donde las herramientas de escaneo fallan. Requiere entender cómo el dinero o la información fluyen por la app.

Confianza Excesiva en el Cliente

$1

Precio de un iPhone

Integridad Comprometida

Ocurre cuando el servidor acepta parámetros críticos como **precios, descuentos o saldos** directamente desde el frontend. Si el backend no tiene una "Fuente Única de Verdad" (DB), el atacante modifica el valor en tránsito con un Proxy y el sistema procesa el fraude.

Análisis de Valores Límite

Cantidades Negativas

¿Qué pasa si pido -1 productos? Si el total es precio * qty, el carrito resta dinero del total, permitiendo comprar otros objetos "gratis" al pagar el saldo remanente.

Integer Overflow

Ingresar valores masivos que superan la capacidad de la variable en el servidor (32/64 bit). El total puede "reiniciarse" a cero o convertirse en un número negativo.

Controles Inconsistentes

- **Bypass de Flujo:** Saltarse pasos obligatorios (Paso 1: Registro -> Paso 4: Descarga) manipulando la URL o estado de sesión.
- **Seguridad Desigual:** Implementar MFA en el Login pero no en el panel de "Cambiar Email", permitiendo el secuestro de la cuenta.
- **Inconsistencia de Verificación:** Permitir acceso a funciones de admin si el usuario simplemente tiene un email con dominio @empresa.com.
- **Estado de Pedido:** Modificar un pedido después de que ha sido validado para pago pero antes de que se envíe el producto.

Aislamiento en Endpoint Dual

Endpoint Compartido (User/Admin)

Ocurre cuando una API sirve datos a usuarios y admins simultáneamente. El servidor diferencia la respuesta basándose en un parámetro (internal=true) o una cookie. Si no hay aislamiento de permisos a nivel de objeto, cualquier usuario puede extraer campos sensibles como roles, tokens de API o hashes de otros usuarios.

Metodología: Mapeo de Flujo

Identificar

Mapear cada paso del proceso de negocio. ¿Qué espera el programador que yo haga?

Cuestionar

¿Qué pasa si salto este paso? ¿Qué pasa si envío un valor nulo? ¿Y si lo envío dos veces?

Explotar

Abusar de la suposición de diseño. Romper el flujo secuencial y la integridad de los datos.

Detección de Vulnerabilidades

La auditoría lógica es donde el especialista justifica su valor frente a la automatización.

Mitigación y Defensa

Amenaza	Defensa Estratégica
IDOR / BOLA	Validación explícita de propiedad en cada petición (owner_id).
Lógica de Negocio	Single Source of Truth (Precios y roles siempre de la DB).
Bypass de Flujo	Máquinas de estado finito en el backend para validar procesos.
Mass Assignment	Implementación de Listas Blancas (Strong Parameters).

¿DUDAS?

Hacking Web 2026soy QBit

github.com/djotahub | vanguardiun.academy

Image Sources

https://img.freepik.com/premium-photo/cyber-security-digital-lock-abstract-circuit-board-background_1307030-17146.jpg?semt=ais_hybrid&w=740&q=80

Source: www.freepik.com

---

https://hicronsoftware.com/wp-content/uploads/2025/06/Complete-web-app-security-checklist-using-the-OWASP-top-10-visual-selection-7-1024x951.png

Source: hicronsoftware.com

---

https://substackcdn.com/image/fetch/$s_!pSR2!,f_auto,q_auto:good,fl_progressive:steep/https%3A%2F%2Fsubstack-post-media.s3.amazonaws.com%2Fpublic%2Fimages%2F5244cbee-8937-468d-b1b6-758cbcafbc75_1920x1080.png

Source: softwareanalyst.substack.com

---

https://d3f1iyfxxz8i1e.cloudfront.net/courses/course_image/cd2356711e6a.png

Source: www.classcentral.com